

Security Risk Assessment — pmx100

Generated 2026-09-13 16:41 UTC · 2 entries · 0 parse-error entries

Summary

Metric	Count
Threats analysed	2
Priority P0 (Critical)	1
Priority P1 (High)	1
Priority P2 (Medium)	0
CVSS Critical (≥ 9.0)	1
CVSS High (7.0-8.9)	1
CVSS Medium (4.0-6.9)	0
CVSS Low / None	0
Residual High	0
Residual Medium	2
Residual Low	0
Total estimated effort (eng-weeks)	4.5

Entry index

Threat	Priority	CVSS	Residual	Effort
DF-BLEPAIR-I — Unencrypted BLE Pairing Traffic Capture	P1	8.1 High	Medium	1.5wk
DF-BLEVITALS-T — BLE Vitals Spoofing via MITM	P0	9.1 Critical	Medium	3wk

DF-BLEPAIR-I · Unencrypted BLE Pairing Traffic Capture

STRIDE: I **CVSS:** 8.1 High **Priority:** P1 **Effort:** 1.5 eng-weeks **Residual risk:** Medium — Implementing LE Secure Connections will mitigate the threat, but residual risk remains due to potential implementation flaws.

The threat of unencrypted BLE pairing traffic capture is critical due to the lack of encryption during the pairing process, allowing adversaries to intercept sensitive data. Implementing BLE LE Secure Connections with numeric comparison or out-of-band authentication will address this vulnerability, enhancing the security of the pairing process.

Existing controls (legacy):

- `CTRL:tls-1-0-for-encrypted-data-in-transit-legacy` — TLS 1.0 for encrypted data-in-transit (legacy)

Gap analysis:

Clause	Verdict	Reason
FDA-2023-V.B.6	MISSING	The threat describes unencrypted BLE pairing in Just Works mode, which the clause explicitly prohibits and requires LE Secure Connections. The existing TLS 1.0 control does not address BLE pairing security.
FDA-2023-V.B.9	MISSING	The clause addresses physical port and debug interface hardening, which is unrelated to the BLE pairing threat or the existing TLS 1.0 control.
FDA-2023-V.B.5	PARTIAL	The existing control uses TLS 1.0 for data-in-transit, which is a form of transport-layer encryption. However, the clause explicitly requires TLS 1.2 or later, making TLS 1.0 a partial fulfillment.
FDA-2023-V.B.4	PARTIAL	The existing control uses TLS 1.0 for data-in-transit, providing some confidentiality. However, TLS 1.0 is not a 'current, standards-based algorithm' as required, and the threat specifically notes unencrypted BLE pairing traffic, which is not covered.
FDA-2023-V.B.8	MISSING	The clause addresses audit logging and event traceability, which is unrelated to the BLE pairing threat or the existing TLS 1.0 control.

Proposed controls:

- `CTRL:PROPOSED:ble-le-secure-connections` — Implement BLE LE Secure Connections with numeric comparison or out-of-band authentication for pairing.

Proposed doc changes:

- SRS.md · **add** `SRS-SEC-NEW-01` — The system shall use Bluetooth Low Energy (BLE) LE Secure Connections with numeric comparison or out-of-band authentication for all pairing processes to ensure encrypted and authenticated communication.

Proposed code changes:

`firmware/ble_pairing.c:0` (create_file)

```
// Implement BLE LE Secure Connections
#include <ble_secure_connections.h>

void setup_ble_pairing() {
    ble_secure_connections_init();
    ble_secure_connections_set_authentication_mode(NUMERIC_COMPARISON);
}
```

DF-BLEVITALS-T · BLE Vitals Spoofing via MITM

STRIDE: T **CVSS:** 9.1 Critical **Priority:** P1 **Effort:** 2 eng-weeks **Residual risk:** Medium — Implementing BLE LE Secure Connections will mitigate spoofing but not eliminate all risks.

The BLE Vitals Spoofing threat allows attackers to manipulate vital signs data by exploiting the lack of cryptographic protection. Implementing BLE LE Secure Connections will provide cryptographic signatures to authenticate and verify the integrity of BLE notifications, significantly reducing the risk of spoofing.

Existing controls (legacy):

- `CTRL:no-cryptographic-signatures-or-crc-validation-for-ble-notifications-relies-on-ju` — No cryptographic signatures or CRC validation for BLE notifications; relies on 'Just Works' BLE trust model

Proposed controls:

- `CTRL:PROPOSED:ble-le-secure-connections` — Implement BLE LE Secure Connections with cryptographic signatures for message authentication.

Proposed doc changes:

- SRS.md · **add** `SRS-SEC-NEW-01` — The system shall use BLE LE Secure Connections to ensure the authenticity and integrity of BLE notifications.

Proposed code changes:

`firmware/ble_communication.c:0` (create_file)

```
// Implement BLE LE Secure Connections
// Ensure cryptographic signatures for message authentication
void setup_ble_secure_connections() {
    // Code to initialize BLE LE Secure Connections
}
```

DF-EMR-T · Man-in-the-middle HL7/FHIR replay

STRIDE: T **CVSS:** 9.1 Critical **Priority:** P1 **Effort:** 2 eng-weeks **Residual risk:** Medium — Implementing modern TLS and integrity checks reduces risk but does not eliminate it entirely.

The current use of TLS 1.0 with weak cipher suites allows for man-in-the-middle attacks on HL7/FHIR data. Upgrading to TLS 1.2+ with certificate pinning and implementing SHA-256 integrity checks will significantly enhance security by preventing unauthorized data interception and modification.

Existing controls (legacy):

- `CTRL:tls-1-0-with-system-ca-bundle-for-cert-validation` — TLS 1.0 with system CA bundle for cert validation

Proposed controls:

- `CTRL:PROPOSED:tls-1-2-with-pinning` — Upgrade to TLS 1.2+ with certificate pinning and AES-256 encryption.
- `CTRL:PROPOSED:integrity-checks` — Implement SHA-256 based integrity checks for HL7/FHIR data in transit.

Proposed doc changes:

- SDS.md · **add** `SDS-SEC-NEW-01` — Implement TLS 1.2+ with certificate pinning and AES-256 encryption for all HL7/FHIR communications. Add SHA-256 based integrity checks to ensure data integrity in transit.

Proposed code changes:

`firmware/network_security.c:0` (create_file)

```
// Implement TLS 1.2+ with certificate pinning
// Implement AES-256 encryption
// Implement SHA-256 integrity checks
```